

1. 개요

본 보고서는 사이버 킬체인(Cyber Kill Chain)의 개념과 역할을 탐구한 내용을 담고 있다. 사이버 킬체인의 유래와 핵심 구성 요소를 살펴보고, 모의해킹과의 관계를 분석하여 실제 사이버 위협에 대한 이해를 높이는 것을 목표로 한다. 이러한 과정을 통해 사이버 공격자의 관점을 이해하고, 효과적인 방어 전략을 수립하는 데 필요한 지식을 습득함으로써 미래의 보안 전문가로서의 역량을 강화하는 데 도움이 될 것이라고 생각한다.

2. 사이버 킬체인의 유래

사이버 킬체인은 미국의 방산업체 **록히드 마틴(Lockheed Martin)**이 군사 용어인 '킬체인(Kill Chain)'을 사이버 보안에 적용하여 만든 모델이다. 군사 킬체인은 적을 Find(탐지), Fix(확인), Track(추적), Target(조준), Engage(교전), Assess(평가) 하는 일련의 과정을 의미하며, 이는 사이버 공격자가 목표를 달성하기 위해 거치는 연속적인 단계와 유사하다. 록히드 마틴은 수많은 **APT(Advanced Persistent Threat)** 공격 사례를 분석하여 이러한 공통된 패턴을 발견하고, 이를 7단계의 사이버 킬체인 모델로 정립했다.

3. 사이버 킬체인이란

3-1. 사이버 킬체인 정의

사이버 킬체인은 사이버 공격이 이루어지는 과정을 7단계로 구조화한 보안 프레임워크이다. 이 모델의 핵심은 공격이 시작되어 최종 목표를 달성하기까지의 모든 단계를 가시화하여, 방어자가 각 단계에서 공격을 차단할 수 있는 기회인 '**킬 포인트(Kill Point)**'를 식별하도록 돕는 것이다. 즉, **공격의 어느 한 단계라도 무력화하면 전체 공격을 막을 수 있다**는 개념을 제공한다.

3-2. 사이버 킬체인 단계

1. Reconnaissance (정찰) : 공격 대상에 대한 정보를 수집하는 단계

- 공격자 관점 : 공개 정보(SNS, 웹사이트), 네트워크 스캔 등을 통해 취약점, 이메일 주소, 직원 정보 등을 파악
- 방어자 관점 : 비정상적인 네트워크 스캔 탐지, 공개된 정보에 대한 관리 강화

2. Weaponization (무기화) : 공격에 사용할 악성코드를 만드는 단계

- 공격자 관점 : 익스플로잇과 악성 페이로드를 결합하여 악성 파일을 생성
- 방어자 관점 : 공격자 내부 활동이므로 탐지 어려움. 다음 단계에서 악성 파일 탐지에 집중

3. Delivery (전달) : 무기화된 악성 파일을 대상에게 전달하는 단계

- 공격자 관점 : 이메일 첨부 파일(피싱), 악성 웹사이트 링크, USB 등 다양한 채널을 이용
- 방어자 관점 : 이메일 보안 솔루션, 웹 필터링, 침입 방지 시스템(IPS)으로 유입 차단

4. Exploitation (악용) : 전달된 악성 파일이 시스템의 취약점을 이용해 실행되는 단계

- 공격자 관점 : 사용자의 클릭, 웹사이트 방문 등을 유도하여 취약점 공격
- 방어자 관점 : 시스템 정기 패치, 보안 업데이트, 안티바이러스 솔루션 활용

5. **Installation (설치)** : 시스템에 백도어 등을 설치하여 지속적인 접근을 확보하는 단계
 - 공격자 관점 : 악성코드 설치, 새로운 사용자 계정 생성 등
 - 방어자 관점 : 파일 무결성 모니터링(FIM), 호스트 기반 침입 탐지 시스템(HIDS)으로 비정상적인 파일 생성 탐지
6. **C&C, Command & Control (명령 및 제어)** : 설치된 백도어를 통해 감염된 시스템을 원격으로 제어하는 단계
 - 공격자 관점 : C&C 서버와 통신하여 명령을 내리고 정보를 탈취
 - 방어자 관점 : 비정상적인 네트워크 트래픽 분석, 방화벽 규칙 강화
7. **Actions on Objectives (행동)** : 공격자가 최종 목표를 달성하는 단계
 - 공격자 관점 : 내부망 추가 침투, 중요 정보 유출, 시스템 파괴 등
 - 방어자 관점 : 데이터 유출 방지(DLP) 시스템, 백업 시스템, 권한 관리 강화

4. 사이버 킬체인과 모의해킹 관계

사이버 킬체인은 공격자의 관점에서 사이버 공격의 진행 과정을 체계화한 모델인 반면, 모의해킹(Penetration Testing)은 방어자의 관점에서 공격자의 관점을 시뮬레이션하여 시스템의 취약점을 찾아내는 보안 컨설팅 방법론이다. 두 개념은 서로 다른 목적을 가지고 있지만, 매우 밀접하게 연결되어 있으며 모의해킹을 수행할 때 사이버 킬체인 모델은 중요한 참고 자료가 된다. 모의 해킹은 ‘우리가 어떻게 공격당할 수 있을까?’라는 질문에 답하기 위한 방법이기 때문에 사이버 킬체인은 이 질문에 대한 가장 구체적이고 체계적인 답변을 제공해줄 수 있다. 모의 해커는 사이버 킬체인의 각 단계를 따라가며 공격을 시도함으로써, 실제 공격자가 어떤 경로로 시스템에 침투할지 예측하고 방어 전략을 수립할 수 있다. 모의 해킹의 일반적인 절차는 사이버 킬체인의 단계와 상당 부분 일치한다. 다음은 모의 해킹의 절차와 사이버 킬체인의 단계를 매핑하여 비교한 것이다.

모의 해킹 단계	사이버 킬체인 단계	유사점 및 매핑 관계
정찰	정찰	공격 대상에 대한 정보를 수집하는 과정. 공개된 정보와 네트워크 스캔을 통해 시스템의 외형을 파악.
스캐닝	무기화, 전달, 악용	스캐닝을 통해 공격자는 취약점(익스플로잇)을 발견하고, 이를 이용해 악성코드(페이로드)를 전달 및 실행할 수 있는 경로를 찾음.
접근 권한 획득	악용, 설치	발견한 취약점을 실제로 공격(Exploitation)하여 시스템에 침투하고, 백도어 등을 설치해 접근 권한을 확보하는 단계.
권한 유지 및 흔적 덮기	설치, C2, 행동	시스템에 침투한 후, 더 높은 권한을 얻고(권한 상승), 지속적인 접근 통로(백도어)를 유지함. 최종 목표를 위한 준비 단계.
결과 보고	-	킬체인의 모든 단계를 모방해 공격을 성공. 모의 해킹의 경우 그 결과를 보고서로 피드백.

모의해킹과 사이버 킬체인은 관점만 다를 뿐, 공격의 진행 과정이라는 측면에서 매우 유사한 단계 구조를 가진다. 모의해킹은 사이버 킬체인 모델을 실제로 모방하는 과정이라고 할 수 있다.

5. 서술자의 주관적인 의견

위에서 조사한 내용을 바탕으로 추가적으로 궁금했던 점들과 알아보고 싶다고 생각한 내용들에 대해 주관적인 생각을 추가하여 정리해보았다.

5-1. 사이버 킬체인이 보안 프레임워크인 이유는 무엇인가?

보안 프레임워크는 조직의 정보 보안을 체계적이고 효과적으로 관리하기 위한 '틀(Framework)' 또는 '지침'을 말한다. 복잡하고 다양한 보안 활동들을 일관된 기준으로 수행할 수 있도록 도와주는 일종의 '설계도'와 같다고 볼 수 있다.

이런 관점에서 사이버 킬체인은 **공격의 각 단계를 분석하고, 각 단계에서 어떤 방어 활동을 해야 하는지에 대한 명확한 지침을 제공하기** 때문에 위협 관리(Threat Management)에 특화된 보안 프레임워크라고 볼 수 있는 것이다. 추가적으로 사이버 킬체인 외에도 NIST 사이버 보안 프레임워크, ISO 27001 등 다양한 목적을 가진 보안 프레임워크들이 존재한다고 하니 추가적인 보안 지침을 공부하기 위해 참고하면 좋을 것 같다.

5-2. 정말 전쟁 전략과 비슷한가? 어떻게 이런 공격자의 관점에서 지침을 만들 수 있었는가?

사이버 킬체인의 출발점은 **록히드 마틴(Lockheed Martin)의 군사 킬체인(Military Kill Chain)** 모델이며 이 모델은 적을 탐지하고, 추적하고, 공격하여 파괴하는 일련의 과정을 체계적으로 정리한 것이다. 즉, 사이버 킬체인은 이미 존재한 군사 킬체인 모델을 사이버 공간의 특성에 맞게 재해석하고 확장한 것이다.

이러한 사이버 킬체인을 만들기 위해 록히드 마틴의 보안 전문가들은 수많은 실제 **사이버 공격(APT: Advanced Persistent Threat)** 사례를 분석했다. APT 공격의 **로그 기록, 악성코드 분석, 네트워크 트래픽 분석** 등을 통해 공격자들이 어떤 순서로 행동하는지 패턴을 파악할 수 있었던 것이다. 예를 들어, 거의 모든 공격이 '**정보 수집(정찰) → 악성코드 전달 → 시스템 침투 → 최종 목표 달성**'라는 공통된 단계를 거친다는 것을 발견했다. 이러한 분석을 통해 공격자들이 의도적으로든 아니든, 정해진 순서와 논리에 따라 행동한다는 것을 밝혀냈다. 그리고 이 패턴을 7단계로 정리하여 '**사이버 킬체인**' 모델을 완성할 수 있었다.

5-3. "어느 한 단계라도 끊어내면 전체 공격을 무력화할 수 있다"는 것이 정말일까?

이 명제는 방어자에게 중요한 가이드라인이자, 방어의 핵심 목표라고 할 수 있다. 만약 아래에서 언급되는 스텝스넷 공격이 '전달' 단계에서 USB를 통한 유입이 차단되었거나, '악용' 단계에서 취약점 패치가 미리 적용되었다면, 그 공격은 실패했을 것이다. 하지만 이 명제에는 다음과 같은 한계도 존재한다.

- **비선형적 공격** : 모든 공격이 킬체인처럼 순차적으로 진행되는 것은 아니다. 공격자는 이미 내부망에 침투한 상태에서 다른 공격을 시작할 수도 있으며, 한 번의 취약점 공격으로 여러 단계를 한꺼번에 건너뛸 수도 있다.
- **방어의 실패와 공격의 성공** : 방어자는 모든 단계에서 성공적으로 방어해야 하지만, 공격자는 단 한 단계의 성공만으로도 최종 목표를 달성할 수 있다.

- **공격 모델의 진화** : 사이버 킬체인이 주로 외부에서 내부로의 침투를 설명하는 모델이라면, 최근에는 MITRE ATT&CK와 같이 내부망에서의 **횡적 이동(Lateral Movement)**이나 **권한 탈취** 등 더 복잡한 공격 기술들을 포함하는 모델이 등장하고 있다.

따라서 “어느 한 단계라도 끊어내면 전체 공격을 무력화할 수 있다”는 킬체인의 명제는 중요하지만, 현실의 복잡한 위협에 대비하기 위해서는 각 단계별 방어는 물론, 공격이 다음 단계로 넘어갔을 경우를 대비한 **다층적인(Defense in Depth) 방어 전략**을 함께 수립해야 할 것이다.

5-4. 실제 발생한 APT 공격 사례와 매핑하기: 스텍스넷(Stuxnet)

스텍스넷(Stuxnet)은 이란의 핵시설을 공격하기 위해 만들어진 악성코드로, 사이버 킬체인 모델과 가장 잘 들어맞는 대표적인 APT 공격 사례이다.

1. **Reconnaissance (정찰)** : 이란 핵시설의 네트워크 환경, 제어 시스템(SCADA)의 종류, 사용 중인 소프트웨어, 그리고 지멘스(Siemens) PLC의 취약점 등을 광범위하게 조사
2. **Weaponization (무기화)** : 이란 핵시설의 원심분리기 제어 시스템을 파괴하기 위한 악성코드(Stuxnet)을 제작 (Stuxnet : 지멘스 PLC를 오작동시키는 페이로드와 윈도우(Windows) 제로데이 취약점을 결합한 방식)
3. **Delivery (전달)** : 외부에 노출된 네트워크가 없는 폐쇄망(Air-gapped network)을 뚫기 위해 USB 메모리 스틱을 활용하여 내부망 유입
4. **Exploitation (악용)** : 윈도우 제로데이 취약점을 통해 자동 실행
5. **Installation(설치)** : USB가 연결되면, Stuxnet은 윈도우의 제로데이 취약점을 이용해 별도의 사용자 개입 없이 자동으로 실행
6. **C&C (명령 및 제어)** : Stuxnet은 감염된 시스템이 평소처럼 작동하는 것처럼 보이게 하면서, 원격에서 원심분리기의 회전 속도를 조작하도록 명령을 내려 네트워크를 장악하고 원격 제어를 위한 드라이버 조작
7. **Actions on Objectives (행동)** : 원심분리기의 회전 속도를 급격하게 높였다가 낮췄다가하는 방식으로 조작해 물리적 파손 유발

5-5. 실제 발생한 APT 공격 사례와 매핑하기: 2025년 SK텔레콤 침해사고

2025년 SK텔레콤에서 발생한 유심 정보 유출 사고도 사이버 킬체인의 여러 단계를 거쳐 이루어진 복합적인 APT 공격의 전형적인 사례 중 하나이다. 과학기술정보통신부의 SK텔레콤 침해사고 최종 조사 결과 발표 보도 자료를 바탕으로 공격자의 행동을 킬체인 모델에 맞춰 분석하면 다음과 같다.

1. **Reconnaissance(정찰)** : 공격자는 SK텔레콤의 시스템 관리망에 대한 정보를 파악하고, 여러 서버에 걸쳐 계정 정보가 평문으로 저장되어 있다는 취약점을 찾아냈다. 이는 공격자가 침투를 위해 필요한 핵심 정보를 장기간에 걸쳐 수집했음을 의미한다.
2. **Weaponization(무기화)** : 공격자는 시스템에 침투하기 위해 원격 제어 및 백도어 기능을 가진 CrossC2 악성코드를 제작했다. 또한, 추가 거점 확보를 위해 웹쉘이나 BPFDoor 같은 다양한 악성코드를 준비했다.
3. **Delivery(전달)** : 공격자는 외부 인터넷 연결 접점이 있는 시스템 관리망 내 서버에 먼저 접속하여 악성코드를 전달했다. 이는 외부에서 내부로 침투하는 첫 번째 발판을 마련하는 단계였다.

4. **Exploitation(악용) 및 Installation(설치)** : 공격자는 평문으로 저장된 계정 정보를 이용해 서버에 접속한 후, 백도어 악성코드(CrossC2)를 설치했다. 이후 이 악성코드를 통해 시스템 관리망 내의 다른 서버와 고객 관리망으로 횡적 이동하며 웹쉘과 BPFDoor 등의 악성코드를 추가로 설치했다.
5. **Command and Control, C2(명령 및 제어)** : 설치된 악성코드를 통해 공격자는 감염된 서버들을 원격으로 제어했다. 이 단계는 장기간에 걸쳐 은밀하게 이루어졌으며, 2025년 4월에 대용량 데이터가 외부로 전송되는 정황이 포착되기 전까지 SK텔레콤은 이를 인지하지 못했다.
6. **Actions on Objectives(행동)** : 공격자는 초기 침투 과정에서 확보한 계정 정보를 이용해 최종 목표 서버인 음성통화인증 서버에 접근했다. 2025년 4월 18일, 이 서버에 저장된 유심 정보 25종, 총 9.82기가바이트를 외부로 유출하며 최종 목표를 달성할 수 있었다.

이 사건을 통해 사이버 킬체인을의 각 단계가 수년에 걸쳐 진행될 수 있으며, 계정 정보 관리 부실과 같은 초기 단계의 취약점이 최종적인 대규모 정보 유출로 이어질 수 있음을 알 수 있었다. 만약 SK텔레콤이 악성코드 발견 시 신고 의무를 준수하고, 계정 정보와 유심 정보를 암호화하는 등 초기 방어 단계에서 철저히 대응했다면 이와 같은 피해를 막을 수 있었을 것이다.

6. 결론

사이버 킬체인은 공격자의 전략을 이해하고 방어에 실질적으로 활용할 수 있는 프레임워크로, 공격의 모든 단계를 순서대로 목록화함으로써 방어자에게 효과적인 ‘킬 포인트(Kill Point)’를 제시해주는 역할을 한다. 따라서 모의해킹과 같은 실질적인 방법론과 결합될 때 그 가치는 더욱 커질 수 있다. 하지만, 모든 사이버 공격이 킬체인처럼 선형적으로 진행되지는 않는다. 특히 침투 이후의 복잡한 행동을 설명하는 데에는 한계가 있다. 이러한 한계를 보완하기 위해 등장한 것이 MITRE ATT&CK와 같은 최신 프레임워크이다. ATT&CK은 킬체인 모델을 기반으로, 공격자가 사용하는 수많은 구체적인 **전술(Tactics)과 기술(Techniques)을 매트릭스 형태로 정리하여 제공한다.**

따라서 현대의 보안 전문가들은 이 두 가지를 결합하여 공격 과정을 입체적으로 분석하고 다층적인 방어 전략을 수립하는 것이 가장 효과적인 방법이 될 것 같다. 이런 과정에서 사이버 킬체인은 공격자의 사고방식을 체계적으로 이해하고, 이를 바탕으로 견고한 방어 체계를 구축하는 데 필요한 사고방식을 길러주는 교과서와 같은 존재인 것 같다. 교과서적인 내용을 바탕으로 어떻게 응용하여 문제 해결에 활용하는 지는 개인의 역량에 달려 있는 것이다.